

Examen Técnico

Especialista Ciberseguridad Digital

Este examen se dividirá en cinco bloques.

Bloque 1 Conceptos de ciberseguridad

Pregunta 1 - 2 ptos

Un equipo SOC detecta cifrado masivo de archivos en curso en un clúster de servidores. El playbook de ransomware indica aislar de inmediato. Sin embargo, el responsable de continuidad de negocio argumenta que aislar interrumpirá un proceso de liquidación SPEI en curso y prefiere esperar 20 minutos a que termine. ¿Cuál es la decisión técnicamente más defendible?

- A) Aceptar la solicitud de continuidad y posponer el aislamiento 20 minutos, ya que el impacto regulatorio de interrumpir SPEI suele ser mayor que el de un incidente de ransomware en etapa temprana.
- B) Aislar de inmediato los hosts en cifrado activo a nivel de red (no apagarlos), y de forma paralela activar el procedimiento de contingencia operativa de SPEI, dado que cada minuto de cifrado activo expande el alcance del daño y el aislamiento de red no necesariamente detiene una transacción ya enviada al sistema.**
- C) Apagar inmediatamente todos los servidores del clúster, incluidos los que no muestran cifrado activo, para evitar cualquier posibilidad de propagación.
- D) Notificar al CISO y esperar su autorización explícita antes de tomar cualquier acción de contención, dado que se trata de un sistema crítico regulado.

Pregunta 2 - 2 ptos

Una organización implementó WAF, EDR en todos los endpoints, segmentación de red por VLAN y cifrado de base de datos en reposo. El CISO afirma que esto constituye una defensa en profundidad adecuada. ¿Qué elemento de análisis es el más relevante para cuestionar esa afirmación?

- A) Que el WAF y el EDR son redundantes entre sí, por lo que mantener ambos no aporta una capa adicional real de protección.
- B) Que la defensa en profundidad requiere como mínimo cinco controles distintos; con cuatro controles la arquitectura se considera incompleta por definición.
- C) Que los controles listados se concentran en red y host, pero no se mencionan controles a nivel de identidad (gestión de privilegios, MFA) ni de detección de comportamiento anómalo en la capa de datos/aplicación, por lo que una credencial comprometida podría moverse lateralmente sin fricción real entre esas capas.**

D) Que el cifrado en reposo es innecesario si ya existe segmentación de red, dado que un atacante con acceso a la VLAN correcta no podría leer los datos de cualquier forma

Pregunta 3 - 2 ptos

Dos hallazgos compiten por recursos de remediación esta semana: (1) una vulnerabilidad con CVSS 9.8 en un servidor de pruebas de carga, sin datos reales, accesible solo desde una VPN de uso interno muy restringido; (2) una vulnerabilidad con CVSS 6.4 en un servicio que valida tokens de autenticación de la banca móvil, expuesto a internet, para la cual ya existe un exploit público funcional (PoC en GitHub). ¿Cuál es el criterio de priorización correcto y por qué?

A) Priorizar el hallazgo (1) porque un CVSS de 9.8 siempre representa mayor riesgo objetivo que uno de 6.4, independientemente del contexto del activo.

B) Priorizar el hallazgo (2), porque la combinación de exposición a internet, exploit público confirmado y criticidad del activo (autenticación de banca móvil) eleva el riesgo real muy por encima de lo que indica el CVSS base, que no considera el contexto de explotabilidad ni el activo.

C) Tratar ambos como igualmente urgentes y asignar recursos de forma equitativa entre los dos, ya que ambos cuentan con un CVE publicado en bases de datos oficiales.

D) Priorizar el hallazgo (1) primero porque, al tener el CVSS más alto, su remediación reduce más rápidamente el puntaje de riesgo agregado reportado a la dirección.

Pregunta 4 - 2 ptos

Un analista junior reporta: 'Vimos tráfico hacia una IP que aparece en una lista de IoCs de hace 8 meses, pero también vimos un proceso PowerShell ejecutando comandos de enumeración de Active Directory que nunca habíamos visto antes en ese host.' ¿Cuál de las dos señales debería generar mayor prioridad de investigación inmediata, y por qué?

A) La IP en la lista de IoCs, porque al estar documentada en una fuente de threat intelligence existe mayor certeza forense de que se trata de actividad maliciosa confirmada.

B) Ambas señales tienen prioridad idéntica, ya que cualquier coincidencia con una lista de IoCs publicada debe tratarse siempre con la misma urgencia que un comportamiento anómalo no catalogado.

C) El comportamiento de PowerShell, porque un IoC de 8 meses puede estar obsoleto (la infraestructura del atacante cambia) mientras que un patrón de comportamiento (IoA) como enumeración de AD no vista antes en ese host sugiere actividad de ataque en curso, independientemente de si coincide con una firma conocida.

D) Ninguna debe escalar de inmediato; ambas deben esperar la confirmación de la herramienta SIEM mediante una alerta de correlación automática antes de iniciar cualquier investigación manual

Pregunta 5 - 2 ptos

Un viernes a las 11pm, un analista escala una posible exfiltración de datos que no está cubierta explícitamente por el playbook vigente. Tú, como líder del equipo, recibes la

llamada. El analista propone esperar a la reunión del lunes con el equipo completo para decidir con más información. ¿Cuál es la respuesta de liderazgo más sólida?

A) Aceptar la recomendación del analista, ya que esperar a tener al equipo completo reunido el lunes reduce el riesgo de tomar una decisión unilateral incorrecta sin el contexto necesario.

B) Tomar tú mismo el control técnico completo del incidente esa noche, indicando al analista que se desconecte, para evitar exponer al equipo junior a una decisión de alto riesgo fuera de protocolo.

C) Aplicar el criterio de impacto potencial para decidir si se activa una respuesta inmediata reducida (containment mínimo viable) esa misma noche con el personal disponible, sin esperar al equipo completo, y abrir después un proceso formal de actualización del playbook; comunicar a los stakeholders relevantes en cuanto exista certeza razonable del impacto.

D) Instruir al analista para que documente el hallazgo en el ticket y lo escale formalmente a más tardar el lunes a primera hora, dado que no existe un procedimiento aprobado para este escenario específico.

Bloque 2: Automatización y Security as Code

Pregunta 6 - 2 ptos

Un equipo de desarrollo se queja de que el pipeline tarda 35 minutos adicionales por los escaneos de seguridad (SAST + IaC scanning + SCA), afectando su velocidad de entrega. Proponen mover todos los escaneos a un job nocturno que corre una vez al día sobre la rama principal. ¿Cuál es la respuesta técnica más sólida a esta propuesta?

A) Aceptar la propuesta, ya que un escaneo nocturno sobre main sigue cumpliendo el principio de 'shift-left' al detectar los hallazgos antes de cada release semanal.

B) Rechazar la propuesta y mantener los escaneos completos en cada pull request sin excepción, ya que reducir la frecuencia de escaneo siempre constituye una regresión de seguridad inaceptable.

C) Diferenciar por tipo de escaneo: mantener SAST incremental y SCA rápido (solo dependencias modificadas) bloqueando en el PR por su bajo costo de tiempo, y mover el escaneo de IaC completo y el SAST full a un job paralelo no bloqueante post-merge con alertas tempranas, recuperando velocidad sin perder cobertura antes del despliegue a producción.

D) Eliminar el SCA del pipeline, ya que es históricamente el escaneo más lento y de menor tasa de hallazgos explotables, y mantener solo SAST e IaC scanning en cada PR.

Pregunta 7 - 2 ptos

Tu organización usa OPA/Gatekeeper como admission controller en Kubernetes para bloquear despliegues no conformes. Un equipo de plataforma reporta que, pese a tener las políticas Rego correctamente escritas y probadas con `opa test`, algunos pods con configuraciones inseguras (containers privilegiados) siguen llegando a producción. ¿Cuál es la causa más probable y la corrección correcta?

A) Las políticas Rego están mal escritas a pesar de pasar las pruebas unitarias, por lo que deben reescribirse desde cero usando un lenguaje de políticas distinto como Sentinel.

B) OPA/Gatekeeper no es compatible con la validación de configuraciones de seguridad a nivel de contenedor, por lo que se requiere una herramienta adicional de runtime security para este caso específico.

C) Es muy probable que las ConstraintTemplates estén definidas pero no exista el Constraint correspondiente aplicado en el namespace afectado, o que el namespace esté en una lista de exclusión (exempt namespaces) mal configurada; la política puede pasar pruebas unitarias aisladas y aun así no estar realmente vinculada (enforced) al recurso en el clúster.

D) El problema es que Gatekeeper solo puede operar en modo 'dry-run' por diseño, por lo que nunca bloquea despliegues reales y únicamente genera advertencias informativas.

Pregunta 8 - 2 ptos

El equipo de DevOps propone resolver el problema de credenciales hardcoded migrando todas las variables de entorno sensibles a un archivo `.env` cifrado con GPG, almacenado en el mismo repositorio, donde solo los miembros del equipo con la llave privada pueden descifrarlo. ¿Cuál es la principal debilidad de este enfoque frente a un gestor de secretos dedicado (Vault / Secrets Manager)?

A) GPG es un algoritmo de cifrado obsoleto y vulnerable, por lo que cualquier solución basada en él debe descartarse sin importar el caso de uso.

B) El enfoque no resuelve la rotación, revocación granular ni auditoría por identidad de las credenciales: una llave privada comprometida expone todos los secretos sin que exista trazabilidad de quién accedió a cuál secreto y cuándo, y rotar un secreto sigue requiriendo redistribuir manualmente el archivo cifrado y la llave a todo el equipo.

C) Almacenar secretos cifrados dentro del repositorio de código siempre constituye una violación directa de cumplimiento PCI-DSS, independientemente del nivel de cifrado aplicado.

D) El verdadero problema es que GPG no soporta cifrado asimétrico, por lo que no es apto para compartir secretos entre múltiples miembros de un equipo.

Pregunta 9 - 2 ptos

Un CSPM reporta cero hallazgos críticos en una cuenta de AWS durante 3 meses consecutivos. El equipo de plataforma concluye que la postura de seguridad de IaC es sólida y reduce la frecuencia de escaneo de Terraform en el pipeline de mensual a solo validación manual ocasional, argumentando que el CSPM ya cubre la detección en runtime. ¿Cuál es el riesgo principal de esta decisión que un evaluador senior debería señalar?

A) Ninguno relevante: si el CSPM no reporta hallazgos críticos durante varios meses consecutivos, es una señal estadísticamente suficiente de que el escaneo de IaC en el pipeline se volvió redundante y puede eliminarse con seguridad.

B) El CSPM y el escaneo de IaC cubren exactamente el mismo conjunto de reglas, por lo que la decisión es razonable y solo debe documentarse formalmente como una optimización de recursos del equipo.

C) El CSPM detecta después del despliegue (ventana de exposición ya abierta, así sea breve) y depende de que el recurso exista; eliminar el escaneo de IaC en el pipeline remueve el control preventivo y aumenta el costo y tiempo de remediación cuando aparezca una mala configuración nueva, además de que

la ausencia histórica de hallazgos no garantiza que el siguiente cambio en Terraform —hecho por una persona distinta o bajo presión de tiempo— no introduzca una configuración insegura.

D) El riesgo principal es exclusivamente de cumplimiento normativo (auditoría), no un riesgo técnico real, ya que ambos controles ofrecen protección técnica equivalente.

Pregunta 10 - 2 ptos

Estás definiendo la política de 'fail the build' para el pipeline. Un ingeniero propone bloquear automáticamente cualquier hallazgo con CVSS ≥ 7.0 sin excepciones, argumentando que es un umbral objetivo, medible y fácil de auditar. ¿Cuál es la limitación principal de usar el CVSS base como único criterio de bloqueo automatizado en un pipeline maduro?

A) Ninguna; el CVSS base es el estándar de la industria precisamente porque fue diseñado para ser usado como criterio único y automatizado de bloqueo en pipelines CI/CD.

B) El CVSS base no considera el contexto de explotabilidad real, exposición del componente afectado ni si existe una ruta de código alcanzable (reachability) hacia la vulnerabilidad; esto genera bloqueos por hallazgos de bajo riesgo real (dependencias no usadas en runtime) y, al mismo tiempo, puede dejar pasar hallazgos de severidad media con alta explotabilidad real, erosionando la confianza del equipo de desarrollo en el gate y aumentando la probabilidad de que se busquen formas de evadirlo.

C) El umbral correcto siempre debe ser CVSS ≥ 9.0 , no ≥ 7.0 , ya que ese es el estándar reconocido formalmente por NIST para los pipelines de CI/CD en cualquier industria.

D) El CVSS base solo aplica a vulnerabilidades de sistemas operativos y nunca debe usarse para evaluar vulnerabilidades de dependencias de aplicación (librerías de terceros).

Bloque 3 Seguridad en la Nube (AWS/GCP)

Pregunta 11 - 2 ptos

Un equipo de auditoría interna (alineado a requerimientos CNBV) solicita evidencia de que ningún usuario IAM en AWS tiene permisos excesivos. El equipo de plataforma responde que 'todos los accesos pasan por IAM Identity Center con SSO y MFA, por lo que el riesgo de permisos excesivos no aplica'. ¿Por qué esta respuesta es insuficiente desde el punto de vista de un especialista senior?

A) Porque IAM Identity Center con SSO y MFA es en realidad menos seguro que usar usuarios IAM estáticos individuales con contraseñas largas, ya que introduce un único punto de fallo de autenticación.

B) Porque SSO y MFA controlan la autenticación (quién puede entrar y cómo se verifica su identidad), pero no garantizan por sí solos que las políticas/roles asignados a cada identidad sigan el principio de privilegio mínimo; un usuario autenticado con MFA puede seguir teniendo un rol con permisos excesivos (p. ej. `AdministratorAccess`) si las políticas asociadas no se revisaron.

C) Porque MFA solo es obligatorio en GCP, no en AWS, por lo que la afirmación del equipo de plataforma parte de un supuesto técnico inexistente en AWS IAM.

D) Porque el uso de SSO siempre implica automáticamente la aplicación de Service Control Policies (SCPs) a nivel de AWS Organizations, lo cual ya cubriría el requerimiento de la auditoría sin necesidad de revisión adicional.

Pregunta 12 - 2 pts

Un arquitecto de la nube en GCP define una Org Policy `constraints/compute.vmExternalIpAccess` que restringe IPs públicas en VMs solo para la carpeta de 'Producción', pero deja la carpeta de 'Desarrollo' sin restricción, asumiendo que el riesgo es menor ahí. Tres meses después, una VM de desarrollo con IP pública es comprometida y usada como pivote hacia la VPC compartida (Shared VPC) que conecta con producción. ¿Cuál fue el error de diseño más relevante?

A) Ninguno; la decisión fue correcta porque las Org Policies, por diseño, deben aplicarse de forma diferenciada entre ambientes y nunca deben heredarse entre carpetas de una misma organización.

B) El error fue usar Org Policy en lugar de IAM bindings, ya que IAM es la única herramienta de GCP diseñada para prevenir movimiento lateral entre VPCs.

C) Asumir que el menor 'valor' percibido del ambiente de desarrollo implica menor riesgo real, sin considerar que la conectividad de red (Shared VPC) puede convertir un recurso de bajo valor en una ruta de acceso hacia recursos críticos; el control debió aplicarse a nivel organización (o evaluarse la segmentación de red entre proyectos/VPCs) en lugar de basarse únicamente en la clasificación de ambiente.

D) El error fue no haber implementado Cloud Armor en la VM de desarrollo comprometida, ya que es el único control capaz de prevenir el pivoteo lateral entre VPCs en GCP.

Pregunta 13 - 2 pts

Tras una revisión, el equipo de seguridad decide reemplazar el acceso SSH directo a instancias EC2 (con puerto 22 abierto a la VPN corporativa) por AWS Systems Manager Session Manager, eliminando llaves SSH y el puerto 22 por completo. Un administrador de sistemas se opone, argumentando que 'sin SSH perdemos la capacidad de hacer troubleshooting profundo y forense en tiempo real'. ¿Cuál es la respuesta técnica más precisa a esta objeción?

A) La objeción es completamente válida y debe cancelarse la migración a Session Manager, ya que ninguna herramienta de AWS puede replicar las capacidades de una sesión SSH interactiva tradicional.

B) La objeción no es válida porque Session Manager no requiere ningún tipo de permiso IAM adicional, lo que en realidad simplifica el troubleshooting al eliminar por completo el control de acceso.

C) La objeción parte de un supuesto incorrecto: Session Manager provee una shell interactiva equivalente para troubleshooting, sin requerir puertos entrantes abiertos ni gestión de llaves, y además agrega capacidades que SSH tradicional no tiene de forma nativa (registro centralizado de sesiones en CloudTrail/S3, control de acceso vía políticas IAM granulares, y posibilidad de revocar acceso de forma instantánea); el verdadero punto a resolver con el administrador es validar que su flujo de trabajo específico (p. ej. transferencia de archivos, túneles) esté cubierto por las capacidades adicionales de Session Manager (port forwarding) y no asumir pérdida de funcionalidad sin verificarlo.

D) La objeción es parcialmente válida solo para instancias Windows, ya que Session Manager fue diseñado exclusivamente para instancias Linux y no soporta troubleshooting en EC2 con Windows Server.

Pregunta 14 - 2 ptos

Tu organización usa Cloud SQL (GCP) para una base de datos que almacena información de clientes regulada. El equipo de desarrollo señala: 'Google ya es responsable de la seguridad de la base de datos porque es un servicio gestionado, así que no necesitamos un proceso adicional de revisión de seguridad para esto.' ¿Cuál es el error en este razonamiento?

A) El razonamiento es correcto: al ser un servicio completamente gestionado (PaaS), la responsabilidad de seguridad recae al 100% en el proveedor, incluyendo la configuración de acceso y el cifrado aplicado por la aplicación.

B) El error es que Cloud SQL en realidad es un servicio IaaS, no PaaS, por lo que la responsabilidad del cliente es total y no comparte ninguna capa con Google.

C) El razonamiento confunde la seguridad 'de la nube' (que sí gestiona el proveedor: parchado del motor, seguridad física, hipervisor) con la seguridad 'en la nube' (responsabilidad del cliente): configuración de reglas de red/firewall de la instancia, gestión de usuarios y privilegios de base de datos, cifrado a nivel de aplicación si se requiere, clasificación de los datos almacenados y cumplimiento normativo aplicable a esos datos — ninguno de estos es responsabilidad de Google bajo el modelo de responsabilidad compartida.

D) El error es menor: solo aplica a Cloud SQL para PostgreSQL, ya que la variante de MySQL sí transfiere la responsabilidad completa de seguridad de acceso a Google.

Pregunta 15 - 2 ptos

Una institución opera en AWS y GCP simultáneamente y usa Okta como IdP federado con SSO hacia ambas nubes. Durante una auditoría, se detecta que un ex-empleado, dado de baja en Okta hace dos semanas, todavía puede ejecutar comandos en GCP usando una cuenta de servicio (service account) con una llave JSON de larga duración que él mismo generó meses atrás y que nunca fue revocada. ¿Cuál es la causa raíz real de esta brecha, más allá de 'falta de un proceso de offboarding'?

A) La causa raíz es que Okta no soporta integración nativa con GCP, por lo que la federación de identidad nunca llegó a cubrir realmente los accesos en esa nube.

B) La causa raíz es que las cuentas de servicio con llaves JSON de larga duración, autogeneradas, existen como un mecanismo de acceso completamente independiente de la identidad federada del usuario (Okta/SSO); la desactivación de su cuenta humana en el IdP no revoca automáticamente credenciales de service accounts que él haya creado, lo cual exige un proceso complementario de inventario y rotación/revocación de llaves de cuentas de servicio, idealmente sustituyéndolas por Workload Identity Federation sin llaves estáticas.

C) La causa raíz es exclusivamente humana: el equipo de TI olvidó ejecutar un paso del checklist de offboarding, y basta con reforzar la capacitación del equipo para que no se repita.

D) La causa raíz es que el MFA de Okta no se propagó correctamente a GCP, permitiendo el acceso sin segundo factor; reforzar las políticas de MFA condicional resolvería el problema de raíz.

Bloque 4 Gestión de Vulnerabilidades y Cumplimiento

Pregunta 16 - 2 pts

Tu programa de gestión de vulnerabilidades define SLAs de remediación basados únicamente en el CVSS base (críticas: 15 días, altas: 30, medias: 90). Un hallazgo de severidad 'media' (CVSS 5.3) lleva 6 meses abierto sin violar el SLA formal, pero corresponde a una vulnerabilidad de deserialización insegura en un servicio interno con acceso a la base de datos de transacciones, para la cual ya circula un exploit funcional en foros especializados. ¿Qué revela este caso sobre el diseño del programa de SLAs?

A) Revela que el SLA está funcionando correctamente: al no haberse violado el plazo de 90 días para severidad media, el programa cumple su objetivo y no requiere ajuste alguno.

B) Revela que el SLA debería reducirse uniformemente a 30 días para todas las severidades medias, sin necesidad de ningún otro cambio estructural en el programa.

C) Revela una limitación estructural: un SLA basado únicamente en CVSS base no reacciona a cambios posteriores en el contexto de riesgo (aparición de un exploit público, acceso a datos críticos), por lo que el programa necesita un mecanismo de re-priorización dinámica (CVSS temporal/ambiental, o un score de riesgo que incorpore inteligencia de amenazas) y no solo un SLA estático fijado en el momento del hallazgo.

D) Revela que el equipo de desarrollo es responsable exclusivo del retraso y que el problema es enteramente de gestión de personas, no de diseño del programa de vulnerabilidades.

Pregunta 17 - 2 pts

Durante una auditoría de cumplimiento (CNBV / Circular 14/2017), el auditor pide evidencia del programa de gestión de vulnerabilidades. El equipo presenta capturas de pantalla del dashboard de la herramienta de escaneo mostrando cero vulnerabilidades críticas abiertas al día de hoy. El auditor lo marca como 'evidencia insuficiente'. ¿Por qué esa evidencia, aunque parece favorable, no es suficiente?

A) Porque las capturas de pantalla nunca son un formato válido de evidencia documental para auditorías de instituciones financieras en México, independientemente de su contenido.

B) Porque una vista puntual del estado actual no demuestra el proceso ni la trazabilidad histórica: no evidencia los plazos reales de remediación frente al SLA definido, las excepciones de riesgo aceptado con su justificación y vigencia, ni el reporte periódico a comités de riesgo; un auditor necesita evidenciar el ciclo completo de gestión en el tiempo, no solo el estado en el momento de la captura.

C) Porque el dashboard de la herramienta de escaneo no puede usarse nunca como evidencia, ya que únicamente los reportes generados manualmente en Excel son aceptados por la CNBV.

D) Porque mostrar cero vulnerabilidades críticas es en sí mismo sospechoso para cualquier auditor, y debe interpretarse como un indicio de manipulación del escaneo, sin importar el contexto.

Pregunta 18 - 2 ptos

En el análisis forense de un incidente en AWS, tu equipo decide tomar snapshots EBS de las instancias comprometidas y luego terminar dichas instancias de inmediato para 'detener el ataque y evitar mayor exposición', conservando solo los snapshots para el análisis posterior. ¿Cuál es el riesgo principal de esta secuencia de acciones desde la perspectiva forense?

A) Ninguno: un snapshot EBS captura de forma completa absolutamente todo el estado relevante del sistema, por lo que terminar la instancia inmediatamente después no representa ninguna pérdida de información forense.

B) El snapshot EBS captura el estado del disco, pero al terminar la instancia se pierde la memoria volátil (RAM) — donde puede residir malware fileless, claves de cifrado en uso, procesos en ejecución y conexiones de red activas — y se interrumpe abruptamente la recolección de logs en tránsito (buffers no flushados) y metadata de red asociada a la instancia (ENI, flow logs en curso); lo correcto es capturar memoria y logs en vivo antes o en paralelo a aislar la instancia, en lugar de terminarla de inmediato.

C) El riesgo principal es exclusivamente de costo, ya que mantener snapshots EBS por tiempo prolongado genera cargos significativos que deben evitarse terminando la instancia rápidamente.

D) El riesgo principal es que AWS elimina automáticamente los snapshots EBS asociados a una instancia 24 horas después de que esta es terminada, por lo que el verdadero error fue no exportar los snapshots a S3 de inmediato.

Pregunta 19 - 2 ptos

Debes presentar al comité directivo (no técnico) un hallazgo: una mala configuración en un bucket S3 permitió, durante 11 días, que cualquier persona con el enlace pudiera leer (pero no modificar) un subconjunto de documentos internos no clasificados como datos personales ni financieros. Un colega sugiere presentarlo como 'incidente de fuga de datos crítico que requiere notificación inmediata a CNBV', para 'curarse en salud'. ¿Cuál es la postura más apropiada para un líder técnico senior en este caso?

A) Seguir la sugerencia del colega y escalarlo siempre como el incidente de mayor severidad posible ante cualquier duda, ya que sobre-reportar nunca tiene consecuencias negativas reales para la organización.

B) Evaluar primero, con el equipo legal/cumplimiento y los hechos reales (tipo de dato, alcance, exposición confirmada vs. potencial), si el evento cumple el umbral regulatorio y de negocio para clasificarse como incidente reportable; comunicar al comité con precisión el alcance real, el riesgo residual y la acción correctiva tomada, evitando tanto la minimización como la sobre-clasificación que puede generar alarmas regulatorias innecesarias y erosionar la credibilidad técnica del equipo a futuro.

C) No comunicarlo al comité en absoluto, ya que al no involucrar datos personales ni financieros no constituye un evento de interés para la alta dirección bajo ninguna circunstancia.

D) Delegar la clasificación de severidad completamente al equipo legal sin aportar el análisis técnico del alcance real, dado que es una decisión exclusivamente normativa y no técnica.

Pregunta 20 - 2 ptos

Tu equipo no alcanza el SLA de remediación de vulnerabilidades críticas (objetivo: 15 días, real: 45 días). Tras investigar, identificas que la causa principal es que los tickets de vulnerabilidades llegan a los equipos de desarrollo sin contexto de negocio ni prioridad clara, mezclados con decenas de otros tickets de soporte. Un compañero director propone resolverlo asignando una penalización en la evaluación de desempeño a cualquier equipo de desarrollo que incumpla el SLA. ¿Cuál es el riesgo principal de esa propuesta y qué harías de forma distinta como líder?

A) Ninguno; aplicar una penalización directa de desempeño es siempre la forma más rápida y efectiva de alinear incentivos entre equipos de seguridad y desarrollo, y debe implementarse de inmediato sin más análisis.

B) El riesgo es que una penalización aplicada sobre un proceso roto (tickets sin contexto, sin priorización) probablemente derive en remediaciones apresuradas y superficiales para 'cerrar el ticket' a tiempo, sin resolver la causa raíz, o en fricción que erosiona la colaboración entre equipos; un mejor camino es primero rediseñar el flujo (priorización con contexto de negocio, integración al backlog de desarrollo, automatización donde sea posible) y alinear incentivos con métricas compartidas (OKRs conjuntos), reservando consecuencias individuales solo si, una vez corregido el proceso, persiste la falta de cumplimiento.

C) El riesgo es exclusivamente legal, ya que cualquier penalización de desempeño vinculada a métricas de seguridad podría considerarse una práctica laboral indebida bajo la legislación mexicana, sin relación con la efectividad del proceso.

D) No hay riesgo relevante siempre y cuando la penalización se documente formalmente en las políticas de RR.HH. de la organización antes de aplicarse.

Bloque 5 Casos de Uso

1. Triage y asesoría a developers - 10 ptos

Tienes un pipeline bloqueado por un CVE crítico y el developer dice que no hay fix disponible y que el negocio necesita el release hoy. ¿Cómo lo manejas y qué le dices al developer?

Criterio: criterio basado en sus experiencias.

2. DAST y API Scanning - 10 ptos

¿Cuál es la diferencia entre hacer DAST a una aplicación web tradicional y hacer API scanning a una REST API? ¿Qué herramientas has usado y qué limitaciones encontraste? ¿Qué otros tipos de escaneo existen y con qué herramientas los has hecho?

Criterio: Experiencia real con herramientas premium, no solo "usé OWASP ZAP" sin detalle.

3. Security Gates - 10 ptos

En el ciclo de desarrollo basado en SecDevOps, ¿cómo estructurarías los distintos gates de seguridad desde el inicio de la programación hasta su salida a producción?

Criterio: Vista de águila sobre su conocimiento del ciclo de desarrollo

4. Madurez del programa - 10 ptos

Si tuvieras que evaluar qué tan maduro está un programa de AppSec en una organización que ya tiene SAST y SCA pero nada más, ¿qué preguntas harías y qué buscarías para saber por dónde crecer?

Criterio: Vista de águila sobre su conocimiento del ciclo de desarrollo

5. Incidente real - 10 ptos

Cuéntame de alguna vulnerabilidad crítica que hayas encontrado y manejado. No el CVE, sino lo que pasó después: cómo se comunicó, cómo se resolvió, qué salió mal en el proceso y cómo lo resolviste.

Criterio: Conocimiento de seguridad con experiencia demostrada

6. Visión - 10 ptos

¿Cómo se ve para ti un programa de SecDevOps maduro en una institución financiera?
¿Qué es lo primero que sacrificarías si los recursos son limitados y qué jamás quitarías?